

# Business Impact Analysis (BIA) for Drata

## 1. Overview

A Business Impact Analysis (BIA) is a cornerstone of any effective business continuity and disaster recovery program. At Drata, where compliance automation and security are mission-critical, a BIA enables informed decision-making around risk tolerance, recovery strategies, and resource prioritization. This document presents an in-depth analysis of how potential disruptions could affect operations, allowing the company to remain resilient and responsive in a dynamic cybersecurity landscape.

This Business Impact Analysis (BIA) is enterprise-wide and encompasses all Drata business units, internal systems, SaaS applications, data repositories, and third-party integrations critical to operations. It includes both customer-facing and internal services essential to compliance automation and continuous monitoring.

Drata is a U.S.-based cybersecurity and compliance automation company that enables organizations to streamline and maintain frameworks such as SOC 2, ISO 27001, HIPAA, GDPR, and PCI DSS. Operating in a regulated cybersecurity SaaS space, Drata serves a global clientele across industries like fintech, healthcare, and cloud-based services.

The purpose of this BIA is to identify and evaluate the operational and financial impacts of potential disruptions to Drata's systems and services. The insights guide the prioritization of recovery efforts, enhance incident response, and inform business continuity planning.

## 2. System Description

Understanding Drata's technical landscape is vital to accurately evaluating potential business impacts. This section provides a detailed overview of the platform's architecture, tools, and operational model to contextualize the downstream effects of system outages or disruptions.

Drata's platform is cloud-native and primarily hosted on Amazon Web Services (AWS), leveraging a microservices-based architecture. The core components of the system include a React-based single-page application (SPA) for the frontend and a suite of Node.js microservices deployed via Kubernetes for backend operations. Data storage is managed using a combination of AWS RDS (PostgreSQL) and DynamoDB, providing both relational and NoSQL capabilities. Continuous integration and deployment are handled through GitHub Actions, with Terraform facilitating infrastructure-as-code deployments. The security stack integrates tools such as CrowdStrike, AWS GuardDuty, and other SIEM solutions for threat detection and incident response.

Drata operates within a zero-trust, cloud-first environment. All services are containerized and governed by strict access control mechanisms, including single sign-on (SSO) and multi-factor

authentication (MFA) via Okta. To ensure operational integrity, development, staging, and production environments are strictly segregated using IAM policies and network segmentation strategies.

The platform supports a user base that includes approximately 200 internal employees and over 3,000 global customers. Drata's strategic partnerships include major cloud and SaaS providers such as AWS, GCP, Salesforce, and Microsoft, as well as multiple audit firms that contribute to its compliance automation ecosystem.

To maintain system resilience and data integrity, Drata performs daily encrypted backups stored in AWS S3 with cross-region replication. AWS RDS instances are configured with point-in-time recovery capabilities, and the organization conducts quarterly disaster recovery (DR) testing and validation to ensure preparedness for service disruptions.

### **3. BIA Data Collection**

An accurate BIA depends on high-quality data collected from various organizational touchpoints. This section outlines the methods used to gather information, as well as the stakeholders involved in validating process criticality and recovery expectations.

Information for this BIA was gathered using a combination of qualitative and quantitative methods. Primary data collection included interviews with department heads from Engineering, Product, Compliance, and Customer Support to understand operational dependencies and process criticalities. This was supplemented by a comprehensive review of relevant documentation, such as service-level agreements (SLAs), disaster recovery (DR) policies, and SOC 2 audit materials, to assess formal recovery expectations and current controls in place. Additionally, the analysis of existing risk registers and historical incident reports helped identify past failure patterns and the effectiveness of mitigation strategies. To validate system criticality, internal surveys were distributed to collect input from various teams regarding essential processes and technologies.

The BIA process included active consultation with several key stakeholders across the organization. These included the Chief Technology Officer and Engineering Managers, who provided architectural and operational insights. The Compliance and Governance, Risk, and Compliance (GRC) team offered expertise on regulatory obligations and audit impacts. The DevOps and Site Reliability Engineering (SRE) teams contributed to the evaluation of system availability and infrastructure resilience. Lastly, Customer Success leadership provided input on client-facing service priorities and support workflows.

## 4. Process and System Criticality

Identifying what truly matters during a disruption is a cornerstone of the BIA. This section ranks business processes by their criticality to core operations and outlines the maximum allowable time they can remain non-functional without causing unacceptable damage to Drata’s business and reputation.

To establish effective recovery priorities, this section identifies the critical business processes that support Drata’s core operations. It maps each process to the responsible department and outlines the potential consequences of disruption. A criticality rating from 1 to 5 is assigned to each process, along with the Maximum Tolerable Downtime (MTD), to help define response priorities in the event of a disaster or significant incident.

| Business Process           | Department     | Impact of Disruption                    | Criticality (1-5) | Maximum Tolerable Downtime (MTD) |
|----------------------------|----------------|-----------------------------------------|-------------------|----------------------------------|
| Customer Compliance Portal | Engineering    | Loss of customer trust, SLA violations  | 5                 | 2 hours                          |
| API Integrations           | Engineering    | Disruption to automation workflows      | 4                 | 4 hours                          |
| Internal Monitoring Tools  | Security Ops   | Delayed detection of security incidents | 4                 | 6 hours                          |
| Audit Readiness Reports    | Compliance/GRC | Legal/compliance penalties              | 5                 | 24 hours                         |
| Customer Support Systems   | Support        | Reduced ability to respond to incidents | 3                 | 8 hours                          |

## 5. Downtime Impact and Recovery Objectives

Downtime not only disrupts services but also leads to financial loss, customer dissatisfaction, and regulatory risks. This section defines measurable recovery targets and the expected impact of downtime on business operations, forming the foundation for robust disaster recovery planning.

This section builds on the previous analysis by outlining specific Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) for each critical process. It also describes the operational impacts that would result from downtime, thereby helping to define both technical and procedural requirements for a timely and effective recovery.

| Process                 | Recovery Time Objective (RTO) | Recovery Point Objective (RPO) | Downtime Impact Description                          |
|-------------------------|-------------------------------|--------------------------------|------------------------------------------------------|
| Customer Portal         | 2 hours                       | 1 hour                         | Affects real-time monitoring and compliance tracking |
| API Integrations        | 4 hours                       | 1 hour                         | Impacts compliance automation flows                  |
| Monitoring Tools        | 6 hours                       | 2 hours                        | Creates detection blind spots                        |
| Audit Readiness Reports | 24 hours                      | 12 hours                       | Risk of audit schedule failures                      |
| Support Systems         | 8 hours                       | 2 hours                        | Delay in incident response                           |

## 6. Resource Requirements

Knowing which technical resources underpin your most vital services is essential for targeted recovery. This section lists and describes the infrastructure components needed to maintain operational continuity.

To support the identified critical processes, this section lists the essential technical resources required for their operation. Each resource is described in terms of its platform, version, and function within Drata’s infrastructure. This mapping enables better planning for infrastructure provisioning and recovery in line with defined objectives.

| Resource Name      | Platform         | Version | Description                                        |
|--------------------|------------------|---------|----------------------------------------------------|
| Compliance Engine  | Kubernetes (AWS) | v1.27   | Manages control mapping and evidence collection    |
| Customer Portal    | React (SPA)      | N/A     | User interface for compliance tracking             |
| Backend Services   | Node.js          | v18     | API logic, workflow automation, system integration |
| RDS PostgreSQL     | AWS              | 13.x    | Core application data storage                      |
| Cloud Storage (S3) | AWS S3           | N/A     | Backup storage for documentation and evidence      |

## 7. Recovery Prioritization

Once critical systems and processes are defined, recovery must be prioritized in a structured manner. This section ranks resources by urgency and suggests failover strategies to reduce downtime.

Based on the criticality of each function, this section ranks the required resources in order of recovery priority. It sets target RTOs and outlines alternate recovery strategies for each resource to ensure service continuity under various failure scenarios.

| Resource           | Priority | RTO | Alternate Recovery Strategy                       |
|--------------------|----------|-----|---------------------------------------------------|
| Customer Portal    | High     | 2h  | Multi-region deployment with load balancing       |
| Compliance Engine  | High     | 2h  | Redundant Kubernetes clusters with auto-scaling   |
| Backend Services   | Medium   | 4h  | Hot standby instances in secondary AWS region     |
| RDS PostgreSQL     | High     | 2h  | Point-in-time recovery with cross-region failover |
| Cloud Storage (S3) | Medium   | 6h  | Replication and access via alternate AWS regions  |

# References

National Institute of Standards and Technology (NIST). (2010). Guide for Conducting Risk Assessments (SP 800-30 Rev. 1). <https://doi.org/10.6028/NIST.SP.800-30r1>

National Institute of Standards and Technology (NIST). (2018). Contingency Planning Guide for Federal Information Systems (SP 800-34 Rev. 1). <https://doi.org/10.6028/NIST.SP.800-34r1>

ISO/IEC. (2018). ISO/IEC 27005:2018 Information technology — Security techniques — Information security risk management. International Organization for Standardization.

Amazon Web Services. (2023). Disaster Recovery of Workloads on AWS. <https://docs.aws.amazon.com/whitepapers/latest/disaster-recovery-workloads/introduction.html>

Drata. (2024). Drata Platform Security Overview. <https://drata.com/resources/platform-security>

Calder, A. (2020). Chapter 14: Respond and Recover. In *The Cyber Security Handbook*. IT Governance Publishing.

Snedaker, S. (2014). Chapter 1: Business Continuity and Disaster Recovery Overview. In *Business Continuity and Disaster Recovery Planning for IT Professionals*. Syngress.